

International Conference on Industry Sciences and Computer Science Innovation

Information security risk management models for cloud hosted systems: A comparative study

Anas Irsheid^{a*}, Ahmad Murad^a, Mohammad AlNajdawi^a, Abdullah Qusef^a

^a Princess Sumaya University for technology, Amman 11941, Jordan

Abstract

Cloud hosting approach is becoming a popular choice for management. Having the information hosted in the cloud increase the risks and threats. A strong Security Model is required to maximize the security and treat risks efficiently. This research aims to analysis the most popular Security Model Methodologies and provide recommendation on the best fit methodology for cloud hosting approach. This research used a comparison model to compare the Security Model methodologies, which are ISO27005, NIST SP 800-30, CRAMM, CORAS, OCTAVE Allegro, and COBIT 5, based on three areas: Applicability, adaptability, and Involvement of the models for a cloud-based hosting approach. The research recommends OCTAVE Allegro as the preferred model for cloud hosting approach, as well as COBIT 5 and CORAS with some tuning. The previous models handle the CIA Triad and focus on the information storage, Processing, and transmission. The ISO27005, NIST SP 800-30, and CRAMM are all describing the risk management and assessment as an abstract and might not provide clear guidelines for cloud risks evaluation and assessment. There are more than 200 security models in the management studies, few are suitable for fast growing and continuously changing environment like the cloud approach, the research value on highlighting the best fit approaches to consider when using a cloud hosting platform, securing the information with a proper model.

© 2022 The Authors. Published by Elsevier B.V.

This is an open access article under the CC BY-NC-ND license (<https://creativecommons.org/licenses/by-nc-nd/4.0>)

Peer-review under responsibility of the scientific committee of the International Conference on Industry Sciences and Computer Sciences Innovation

Keywords: Cloud Risk Management; Cloud Hosting.

* Corresponding author. Tel.: +962 787 319 319

E-mail address: anas.irshaid@gmail.com

Introduction

What are Information Systems? Definitions for these two words have been set by many scholars and scientists. Information itself is defined as the transformation of readings, records, numbers, and any raw data that is been collected manually (Human filling a form or an invoice for example) or automatically (sensors on machines sending data), to a useful form and format that can be used in more clear and informative representation. The Information System is the structure of the process that is set to manage the collection, transformation, storing, and processing the information (sometimes the raw data as well), providing visibility for the users of the outcome and the process status within the system[1]. Information Systems have evolved rapidly in the last 10 years comparing to the previous decades. Information Systems Digitization made significant changes to the structure of the Information Systems, and hence, the capabilities that the system can have and the services that it can cover has also been enhanced in a big way[2]. The evolution of the technologies has changed the way people are doing business[3]. Online shopping for example, have evolved significantly in the last 10 years, and even more in 2020 with the rise of COVID-19 pandemic, when regulations and restrictions forced the citizens to follow strict guidelines with social distancing, encouraging them to use online platforms for shopping and communication rather than the traditional brick-and-mortars shopping[4]. With this evolution, leaders and managers have found that the amount of information that they are getting from their systems has become bigger, and later, and with the help of the data scientists and engineers, they found that the information is even become richer and has more values [5]. The world has started to focus more on the information that information systems have and try to extract knowledge from it. This knowledge for some company represents the core business secret that are not allowed to be shared with even the company employees, only specific members can have that access due to its sensitivity and confidentiality of that knowledge[6]. But the extraction of the knowledge and even processing the information as a normal task comes with a cost. The Digital Transformation and all the processes related to it, including knowledge management, required a significant change in the business model, the business processes, and IT strategies to comply with the business strategies and directions[7]. Focusing on the IT part, the Information Systems now has become critical to the business process, and a proper strategy plans needs to take place to ensure the business continuity and information security is always maintained. The information itself has grown big, some businesses have data stored in terabytes, like banking sector storing millions of financial and non-financial transactions every day, some businesses have even more like telecommunications companies and internet providers [5]. The computational requirements for Information Systems that can handle that amount of data without affecting the business has become a challenge [8]. And with the growing demand for new services and businesses requirements, it means more focus on optimizing the processes and IT infrastructure to serve a better customer experience and manage all the complexity behind in a transparent way to end users. In the normal setup, companies have usually a specific IT infrastructure that is used to manage the communication and host the Information systems locally at the company premises. The IT infrastructure consists of many components, starting from the terminal that the users (employees) use, or machines in factory, the networking that manages the communication, reaching to the datacenter that hosts the Information System Application Servers[9]. In between, there are many rules and policies that takes in place to ensure the CIA Triad (Credibility, Integrity, and Availability) of Information at input, transmission, and store of the information [10]. Taking the CIA in consideration when implementation any security plans, and apply it on the policies and standards on the companies Information security infrastructure and Information Management is becoming a basic requirement for the companies hosting their Information systems on any environment [10]. On premise environment has its pros and cons. For instance, companies with on premise setup feels more in control in managing the IT infrastructure, have access to all resources, secure backups, and direct visibility to all system components in the company, applying CIA Triad consideration and always maintaining it [11]. On the other hand, the cost of maintaining the availability of the information becomes a challenge and put responsibility directly into the IT staff managing the IT infrastructure at the company. Also, the cost of maintain the hardware, the cooling system, the datacenter setup, expansion of server capabilities for storage of computational power, and upgrading process for hardware and software parts are few of the challenges that most of the IT personals faces in their daily routine [12]. Those type of challenges could significantly affect the businesses. The decline in availability percentage of many online business means losses in revenue, reputation, or even credibility of the company. The top-level management by nature will not accept any of that to happen, so they plan a proper information security management plan to make sure that business in online,

services are available to users internally and externally, the information are secured and protected, and users and customer experiences are always excellent [13]. And for that to happen, business owners and top management teams will always look for the solutions that minimize risks, and enhance efficiency, and increase revenue, and to handle the IT challenges, many businesses have started to investigate outsourcing part, and sometimes the whole IT tasks to a professional IT providers and companies to mitigate those risks. Cloud Hosting Providers like Amazon (Amazon AWS), Microsoft (Microsoft Azure), and Google (Google Cloud Services) have all started to capitalize a significant investment on this strategic direction. Cloud Hosting Services provides lots of benefits for businesses, small or big, critical, or normal, complex, or simple, and facilitate a flexibility to expansion with minimum efforts. Cloud Hosting providers even provide services like storage or computational power capacity expansion, up-to-date platform, 24/7 support, high availability of services, security standards, business continuity strategy and many other services that attracts business owners and top management to consider cloud hosted services as a valid option to minimize information systems IT related risks. Cloud Hosting Services might be a great option here, but it has some drawbacks as well. Losing the firm hand that controls the infrastructure and the information might be very critical for some businesses. In the Financial Sector, local regulators have not yet standardized the process of technology enablers, like cloud hosting and computing. In many countries central banks have still restricting the usage data migration from on premise to cloud hosting due to the privacy of the data, and that is not only related to the user privacy, but sometime to national security and politics concerns. Also, since the data is hosted in the cloud, it means that its accessible through the internet, rather than private network in case of on-premises setup, which means it might be more vulnerable to attacks. Cloud Hosting Security is a critical requirement, and it's not optional. Cloud Security should have a very powerful security model that can adapt to the changes in the environment, applicable to the cloud setup, and involving the right resources to manage the risks effectively. Among the many security models available nowadays, the most popular ones are ISO27005, NIST SP 800-30, CRAMM, CORAS, OCTAVE Allegro, and COBIT 5. The research questions for this study are firstly how applicable is the aforementioned security models on cloud hosting environment. Secondly, are those security models adaptable to the changing environment of the cloud settings. Lastly, is how are those models provide involvement of the resources in maintaining the security of the systems in the cloud. The research has been constructed to analysis the most popular security models and provide a recommendation on the best-fit model for cloud risk management. Protecting the information wherever it is hosted, cloud or on premise, is a mandatory requirement for any Information System. Cloud Hosting with a suitable security method that could meet all the requirements and challenges to maintain the security of the information, the Information System will always be protected, given that the model is applicable, adaptive, and effectively engaging to manage all type of Risks that the cloud hosting might face.

1. Literature Review

In Cloud technology era, organizations start to host their applications, services, and information assets on the cloud systems. The transformation of the hosting strategy from on premise to cloud has been evaluated based on :1) high availability of their services and systems;2) accessibility to organization information asset will be anywhere at any time; and 3) Cost effective model that help reducing the organizations operational cost that is associated with ownership of the information's systems and assets[14]. Cloud providers offers the cloud service for the organizations based on three essentials models which are Software as a Service (SaaS), platform as a Service (PaaS), Infrastructure as a Service (IaaS), where the organization can select the best model that serves its need and business model. IaaS provide virtual infrastructures like HW, NW, OS for IT services where PaaS provides platforms services like database, middleware. Whereas SaaS provides a services and application that end customer can interact with [15]. High security requirement needs to be applied on the cloud systems that increase the data protection against any external or internal threats. The shift of the information systems assets from on premise information systems to the new models also carries potential risks that could affect dramatically the organization business. As more centralization toward the cloud implies on a huge risk of losing, breaching, compromising the core information assets for any organization. Therefore, there is clear need for an efficient Risk management plan and models to protect the core information assets [16]. Risk management is divided into two stages, which are risk assessment stage and risk mitigation stage. Risk assessment includes the determination of threats, which can destroy the organization information assets and evaluating the probable damage that these threats can cause to the system;

whereas, risk mitigation is the stage to deal with the identified risk and eliminate it [16]. With the quick evolution of the cloud services, there has been many security models that exists, and according to El Fray [17], there are more than 200 security model exists. There are some widely used methods developed to evaluate the risks that can be used valuate and assess the threats affecting the cloud systems and services like ISO27005, NIST SP 800-30, CRAMM, OCTAVE, CORAS, and COBIT.

2.1. ISO27005

ISO27005 standard constitute the organizations to build a security team, who will be responsible for building the security plan for the organization. The standard contains a systematic step for Risks Management. The below steps illustrate ISO27005 approach for Risk Management [18]:

- Step1: The organization will perform a risk identification activity.
- Stpe2: The organization perform a risk assessment that relates to their business.
- Step3: The team should understand the probable impacts and effects of the identified risk.
- Step4: The organization must prioritize the risk treatment approaches.
- Step5: The team must prioritize the actions to reduce the risk occurrence.
- Step6: The organization must involve the Stakeholder for risk management decisions.
- Step7: The risk treatment monitoring is set in addition to perform a regular monitoring to the risk management procedure.
- Step8: The team must document all information to improve the risk management process.
- Step9: The organization must conduct a training to the organization staff about the risk and all action implemented to eliminate it.

The approach as seen for the ISO27005 is to identify the assets, threats that are targeting the organization, vulnerabilities or weakness, controls, likelihood ,and finally the consequences [19].

Figure 1 below shows ISO27005 Risk Management process.

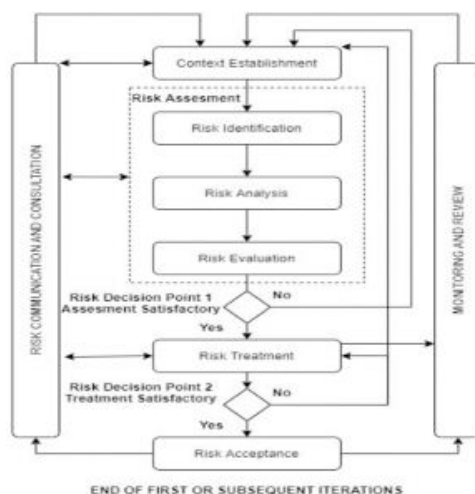


Figure 1 ISO27005 Risk Management Process

2.2. NIST SP 800-30

The second most popular method that deal with Risk Management is NIST SP 800-30. NIST can evaluate and enhance the institute capabilities to stop, detect, and respond to cyber-attacks. Which is one of the most widely used Risk management methodology. The NIST SP 800-30's Risk Management process includes the below phases [20]:

- Phase1: Organization perform a Risk framing which is to build a risk management strategy that illustrate how organizations want to evaluate the risk to generate a risk management strategy that include how the organization will assess, respond, and monitor the risk.
- Phase2: In the second stage the organization, perform a risk assessment to evaluate the risk within the context of the organizational risk frame to determine threats, Vulnerabilities, the harm which may happen and finally the likelihood the harm will occur.
- Phase3: In the third phase, how the organization will respond to the risk once the risk is determined during the evaluation phase by creating steps of action to respond to the risk, actions evaluations, determining the proper action and finally implement the response based on the prioritized actions.
- Phase4: represent how the organization will perform a risk monitoring activity to keep an eye on the risks, and that is to see the effectiveness of implementing the actions, determine the impact changes on the organization and verify that all desired actions are implemented well.

As shown on the below Figure 2, which illustrate the Risk management process used by NIST SP 800-30 standards:

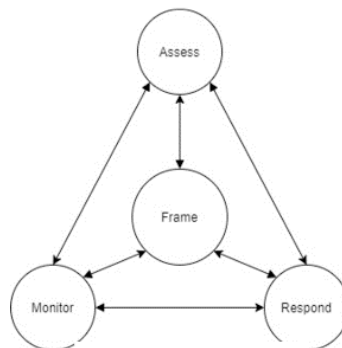


Figure 2 NIST SP 800-30

2.3. Octave Allegro

OCTAVE model developed by the U.S. Department of Defence (DOD), that strengthen the engagement of the organization goals and objectives with the organization information security plans. This model is focusing on organization information assets. OCTAVE standard mainly checks the threats that are targeting the organization information assets, and also the vulnerabilities that weakens the systems and increase the threat possibility [21]. OCTAVE method is implemented over four stages [22, 23]:

- Phase1: In the first stage the organization create a risk measurement criterion to quantify the impact level of the risks by providing a ranking system to be used during the risk management process, and this Step 1.
- Phase2: In stage two, the organization must do two steps. Step 2 is to develop an information asset profile, and then in Step 3, the organization to evaluate the information systems infrastructures to prioritize the critical infrastructures and the assets containers, both internal or external, and resources like software, hardware, network, and individuals.

- Phase3: in stage three the organization implement two steps, step 4 and 5. Step 4, the organization use brainstorming techniques to determine concern areas related to the risks. Then in step 5, it identifies the possible risk, threats probabilities, and their impacts in order to prepare for threat scenarios.
- Phase4: In this stage, there are three steps to be done. The organization identify the risks in Step 6, establish a risk analysis in Step 7, and measure their impact to create a mitigation plan in Step 8.

Figure 3 illustrates the four stages approach adopted by OCTAVE Allegro methodology for risk management:

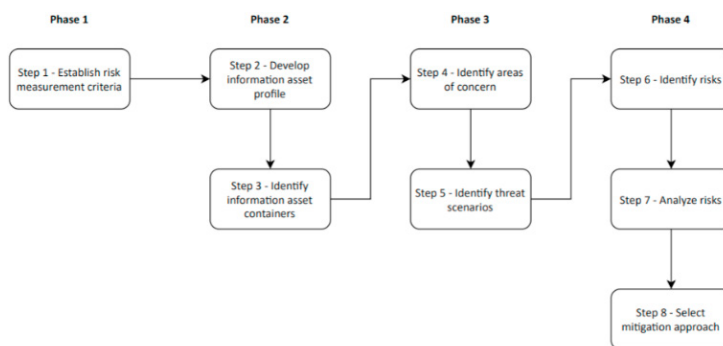


Figure 3 OCTAVE Allegro

2.4. CRAMM

CRAMM (CCTA Risk Analysis and Management CRAMM (CCTA Risk Analysis and Management Methodology) is an approach built by the British Government organization CCTA (Central Communication and Telecommunication Agency). In this method, the risk management is divided into three phases:

- Phase1: In the first phase the organization, perform an asset identification and assessment.
- Phase2: In the next phase, the team will assess the threats by identifying the type and the level of the threat that could affect the systems, and the vulnerabilities. Then, evaluating the threat and vulnerabilities to create a measure for the risk.
- Phase3: Finally, in the last phase the team build and select a mitigation strategy and recommendations.

The below graph illustrate the CRAMM approach for risk management [24]:

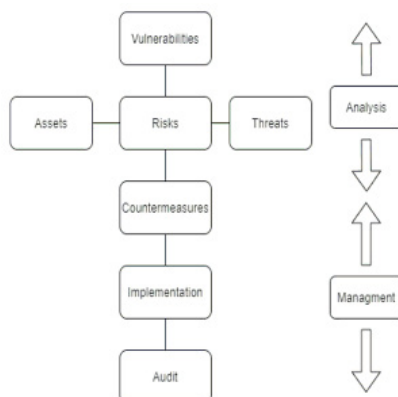


Figure 4 CRAMM

2.5. CORAS

CORAS methodology was built and funded by the European Commission between 2001 and 2003, CORAS built a practical framework model-based security risk assessment. CORAS approaches the risk management by 8 steps for security analysis [25]:

- Step1: The first step primary goal is to set the basic target and the size of analysis to be performed.
- Step2: In the next stage, the approach requires to meet the customers that the analysis is performed for to have an idea of what is their need and requirements that they wish to analyse to reach to a common understanding for required analysis.
- Step3: Is to assure a mutual understanding for the aim of the analysis that includes the focus, scope, and the organization assets.
- Step4: The process implies in a documentation of the analysis that contain the main target, the focus and the aim are properly set and correct.
- Step5: this step includes the risk identification through a brainstorming, walkthrough, and workshops with the related individuals.
- Step6: is to determine the risk level based on the previous step to estimate the risk impact.
- Step7: The organization determine which risk can be accepted and which risk need to deal with and requires a further treatment.
- Step8: The organization will identify and assess the treatments.

It is worth to mention that the approach is built based on UML (Unified Modelling Language), which is a language that apply diagrams to explain relationships and correlation between both the users and the environment[21]. And since it contains a threat modelling for software and distributed systems, this makes CORAS adaptable in the cloud based systems[26].

Figure 5 below, illustrate the CORAS methodology approach:



Figure 5 CORAS

2.6. COBIT 5

Started in 2012, Control Objectives for Information and Related Technology (COBIT 5) is a Model designed by the Information Systems Audit and Control Association (ISACA) that helps in risk management and risk assessment for an organization information asset hosted on cloud and the effect of these risks on the organizations. The approach for COBIT 5 depends on five essential rules in addition to seven enablers for organization IT management [27]:

- Rule1: The first rule is to transform the stakeholder needs (extracted from the stakeholder strategy) into practical and customized goals.

- Rule2: The second rule is to cover the enterprise end-to-end. IT and business functionalities are more integrated. IT tools are important to all business functions; COBIT-5 tries to integrate governance of enterprise IT into concept of enterprise governance.
- Rule3: The third step is to apply, a single integrated framework that is aligned with all other standards for enterprise COSO, COSO ERM, ISO/IEC 9000, ISO/IEC 31000, and other IT related standers like ISO/IEC 38500, ITIL, ISO/IEC 27000 series, TOGAF, PMBOK/PRINCE2, CMMI. As a result, it may serve as the overall foundation for enterprise IT governance.
- Rule4: The fourth rule or key is to enable a holistic approach to for the entire enterprise to manage its IT and information assets. Because a system's integrity and longevity depend on all elements working together, effective management and governance of a foundation necessitates a holistic approach that considers all interconnected functions, elements, and standards without overlooking any department or process.
- Rule5: Finally, separate governance from management. Separating the notions of management and governance is one of COBIT-5's most important features. Management proposals, builds, runs, and monitors actions according to the direction instructed by the governance body to obtain organization objectives, as governance must ensure that the needs of the stakeholders, priorities, conditions, and options are deemed, evaluated to set the organization objectives. And provided direction through prioritization in decision making, monitoring activities and testing compliance against given directions and objectives.

Figure 6 below, illustrates the 5 key principles of COBIT 5:

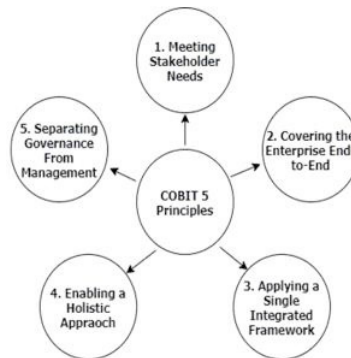


Figure 6 COBIT 5

To enable the holistic approach and the information security plan, COBIT has seven enablers discussed below:

- Enabler1: Is to apply the principle, policies, and framework approach in which represent the platform to transform the required behaviour into a practical guidance for daily management activities.
- Enabler2: Is the process in which the organization define a group of steps and actions to obtain both the objectives and targets. Processes and workflows are a group of practices and actions that are used to achieve specific goals and provide a group of outputs in support of overarching IT objectives.
- Enabler3: The organization will identify the organizational structure which as the key decision-making entities. Organizational structures: The major decision-making entities in a business are organizational structures. Separation of roles, authority, and departments are all important aspects of a successful and responsible organizational structure, which is mostly determined by rules and associated legislation.
- Enabler4: The culture, ethics, and behaviour are set and defined as they are representing the success to factor for the management activities. Governance and management actions will not be productive unless people are involved, corporate principles are adhered to, and professional attitudes are committed. Corporate culture growth hinges on the formation of codes of behaviour or ethics. To offer synergy, organizational learning, and cooperation, corporate ethics and culture must be in harmony with the local and areas partners.

- **Enabler5:** The information, which is the key factor of our survey. Where in this approach the enterprise should deal with all information generated by the organization, as it is needed to keep the business running. Although information is essential to keep the organization functioning and well-governed, at the level of operation, knowledge, information, and strategic business acumen are enterprise's primary products. Both management success and control awareness, including risk aversion, depend on how and when information and communication activities are used. As a result, a seamless flow of needed information between departments and with stakeholders, as well as organizational knowledge regenerations and management, is critical for COBIT-5 implementation.
- **Enabler6:** Identify all the services, infrastructures and application that process and transport the organization information. IT systems that support the company with IT services, IT infrastructure, and applications, should be suited to business requirements and linked with organizational strategy.
- **Enabler7:** Finally, people competencies are the key factor for successful activities. These are essential for the successful completion of all activities, as well as the ability to make rational decisions and take corrective, detective, and preventive actions. It is hard for businesses to survive in competitive marketplaces and a changing the entire environment without effective human capital planning and HR management intended for competent personnel. Human resources are the prerequisites for all functionalities and objectives.

Figure 7 below, represent the seven COBIT 5 Enablers:

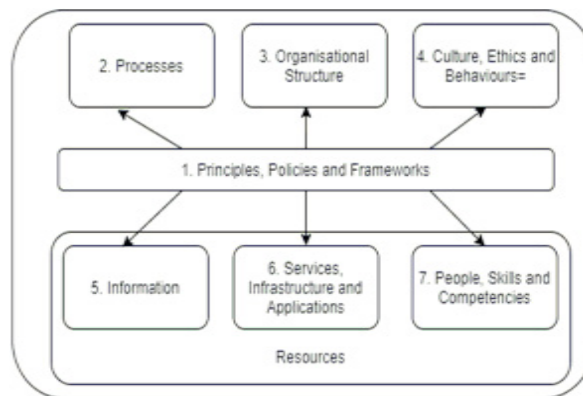


Figure 7 COBIT 5 Enablers

3. Discussion

As business, adopting cloud hosting more often, the requirement for security risk protection is becoming mandatory when companies choose the cloud for hosting their application and business. To distinguish between the many security models that has been discussed before, the methodology that this research is adopting has been constructed based on the below aspects:

- **Applicability:** the applicability of the model for the cloud risks management.
- **Adaptability:** Security Model adaptability for the quick changing cloud environment.

Involvement: The resources involvement in building and maintaining the risk management plans.

The below chart represents the research methodology:

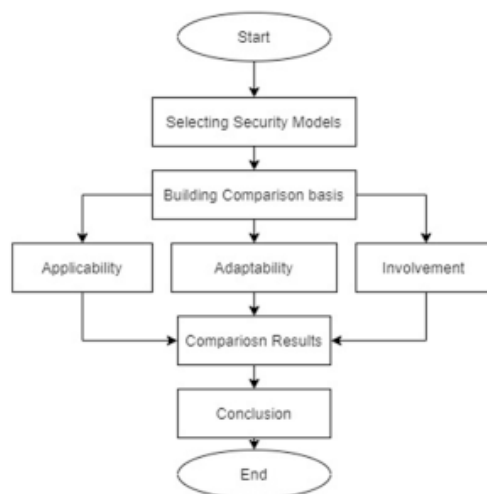


Figure 8 Research methodology

The security models that were discussed has been applied in many areas based on the approaches that each model has develop. The applicability of the selected framework depends on understanding the organization business objectives and the Risk Management Model. After evaluating the acceptable risks, a review for different risk management approaches would be done to choose the best approaches that suites business objective. Additionally, organization can create a customized risk management approach by selecting component from different frameworks resulting in a framework serve the business objectives. Cloud environment security management is always changing to adapt the evolving threats and risks. The adaptability of the security model is a critical requirement when consider it for the cloud environments. Starting with the ISO security model, the model has proven its flexibilities in handling the risks with the structured phased approach. Comparing to NIST security model, the model has some specific controls in the process that might affect the extension of processes for new cloud infrastructure settings. For example, the cloud vulnerabilities are always evaluated to ensure the maximum security, the NIST put the restriction to evaluate the risks in a systematic way not generic method that could help in providing quicker assessment to the risks. Resources Involvement is also an important aspect to look for when evaluating the security model to use, the more the model requires resources to be involved in the process, the more the cost of the model would be. In comparison for the mentioned methodologies in the literature, each approach has an advantages and disadvantages that support the selection of the proper risk management methodologies for cloud-hosted systems in terms of applicability, adaptability, and involvement. ISO27005 is a detailed structured systematic approach that provide a guideline for information security risk management. ISO27005 does not recommend any risk assessment methodologies but it provide a detailed process that help the organizations to perform a risk assessment at an abstract level. Moreover, it does not provide practical procedures to complete each step. Thus it is a bit ambiguous to interpret cloud risks, specifically because the cloud systems are highly interconnected and fast changing technology, Which makes it difficult to be applicable and adaptable approach for risk management in cloud-hosted system [28]. In addition, the cloud risks are more specific and need more powerful methodology to assess and mitigate the risk rather than a systematic approach [29]. Moreover, it doesn't provide support for cloud environment specifications which makes it applicable for traditional IT systems [30]. When discussing NIST SP 800-30 standard ,it provides a risk assessment methodology based on a clear systematic approach with tables and figures ensuring that the approach is accurately implemented, which is also another systematic approach like the ISO27005 that describe the risk at abstract level which makes it difficult to be applicable for cloud computing systems [28, 31]. OCTAVE differ from the previous two approaches as it focus more on organizational risks, practices, and most importantly the technology, where it is examined in relation to practices on security. OCTAVE has developed an automated tool to support organization to implement OCTAVE practices [22]. In OCTAVE, all operational threats are taken into account, which increase the accuracy[32], and makes it adaptable to change as the system operations

are always changing, depending on the systems and technologies. Organization can make decision based on all risks related to CIA triad. As it is a major step in OCTAVE allegro to identify the asset, external or internal containers supporting that this approach can serve inside or outside the organization boundaries [23]. As OCTAVE include the aspects of processing, storing and transformation of the information assets, that makes it much more applicable to cloud-based system compared to the previous two methods. In addition, this approach requires involvement of individuals inside the organization to participate and lead the risk evaluation [21]. CRAMM is a conventional risk management approach, that analyse information systems after determining the risks. Since it is not developed since 2015 this approach has not included a cloud risk assessment in its methodology [33]. Additionally, the approach of CRAMM does not talk about CIA triad dimensions which makes it not applicable, adaptable to cloud bases systems. CORAS is another methodology that is a model-based approach for security risk assessment that provide a computerized tools to support ,maintain, document, and report assessment outcome through the model [32]. Moreover, since it uses threat modelling for distributed systems and software; it makes it more applicable and adaptable for change for Cloud based systems for risk management [34]. Furthermore, this approach assess risk based on diagram that uses a brainstorming and walkthrough interviews for individuals to involve them in the process of risk management [25]. Finally, the cloud-based systems, the ownership does not mean physical access to the information assets only but also governance, compliance, responsibility, and accountability are critical for distributed system and requires new approach to deal with the associated risks. COBIT 5 approach 5 includes RACI measure, which means that the stakeholders to be involved and responsible, accountable, consulted, and informed related to IT Governance processes. Here we can point to COBIT 5 approach which include not only risk management process but it include also Risk governance to control and monitor the security policies applied on information assets, makes it also applicable and adaptable to cloud bases systems as a risk management and governance approach [35].

4. Conclusion

There are many approaches and methodologies that are related to security risk management and assessment. The goal of this study was to perform a comparative analysis for the most used risk management methodologies and their applicability, adaptability, and involvement to the cloud- based systems. Most of the companies started to migrate their information assets to cloud-based infrastructure due to many reasons like cost, availability, and scalability. Thus, the more information assets are migrated to cloud-based systems the more and new risks are associated with this migration that require a great attention to follow a proper and well-designed approach for risk management, assessment, and governance approach. The research recommends OCTAVE Allegro as the preferred model for cloud hosting approach, as well as COBIT 5 and CORAS with some tuning. The previous models handle the CIA Triad and focus on the information storage, Processing, and transmission. The ISO27005, NIST SP 800-30, and CRAMM are all describing the risk management and assessment as an abstract and might not provide clear guidelines for cloud risks evaluation and assessment. The OCTAVE, CORAS and COBIT5 Security models have a clear process to deal with the risks associated with both external and external systems and software resources. In addition to that, they included the cloud-specific infrastructure, like containers and other resources when evaluating the risks. COBIT 5 specifically, have additionally covered the governance part when dealing with cloud system. The three models ensure confidentiality, availability, and integrity of the information assets. On the other hand, ISO27005, NIST SP 800-30 and CRAMM are high level, abstract approaches that provides an overall process for risk management, not focused on cloud-based infrastructure. Yet these approaches still can be developed and customized to be able to use and apply them on the cloud-based infrastructure, but this will require more research to integrate and customize the mentioned approaches and can be a great topic for future research. This research focus on 5 risk management approached as mentioned in the literature review where more approaches are available in the market that can be explored and evaluated. Additionally, a qualitative research can be conducted to assess different risk management approaches, finally this study evaluated the different risk management approaches based on three different angles that are the applicability, adaptability, and involvement however, more factors can be engaged for the evaluation process.

References

- [1] K.C.Laudon and J.P.Laudon, "Management Information Systems: Managing the Digital Firm," in *Management Information Systems: Managing the Digital Firm* Harlow, England: Pearson, 2018, pp. 398-443.
- [2] J. Ross. (2017, September 29) Don't Confuse Digital With Digitization. *MITSloan Management Review*.
- [3] J. Firth et al., "The "online brain": how the Internet may be changing our cognition," *World Psychiatry*, pp. 119-129, 2019.
- [4] M. A. Salem and K. M. Nor, "The Effect Of COVID-19 On Consumer Behaviour In Saudi Arabia: Switching From Brick And Mortar Stores To E-Commerce," *International Journal of Scientific & Technology Research*, pp. 15-28, 2020.
- [5] T. H. Davenport, P. Barth, and R. Bean, "How big data is different," 2012.
- [6] A. Mardani, S. Nikoosokhan, M. Moradi, and M. J. T. J. o. H. T. M. R. Doustar, "The relationship between knowledge management and innovation performance," vol. 29, no. 1, pp. 12-26, 2018.
- [7] S. Chanas, M. D. Myers, and T. J. T. J. o. S. I. S. Hess, "Digital transformation strategy making in pre-digital organizations: The case of a financial services provider," vol. 28, no. 1, pp. 17-33, 2019.
- [8] C. Ning, F. J. C. You, and C. Engineering, "Optimization under uncertainty in the era of big data and deep learning: When machine learning meets mathematical programming," vol. 125, pp. 434-448, 2019.
- [9] G. Andreadis, L. Versluis, F. Mastenbroek, and A. Iosup, "A reference architecture for datacenter scheduling: design, validation, and experiments," in *SC18: International Conference for High Performance Computing, Networking, Storage and Analysis*, 2018, pp. 478-492: IEEE.
- [10] D. Sampson and M. M. Chowdhury, "The Growing Security Concerns of Cloud Computing," in *2021 IEEE International Conference on Electro Information Technology (EIT)*, 2021, pp. 050-055: IEEE.
- [11] L. J. Nieuwenhuis, M. L. Ehrenhard, L. J. T. f. Prause, and s. change, "The shift to Cloud Computing: The impact of disruptive technology on the enterprise software business ecosystem," vol. 129, pp. 308-313, 2018.
- [12] A. El Mhouth, M. Erradi, A. J. E. Nasseh, and I. Technologies, "Using cloud computing services in e-learning process: Benefits and challenges," vol. 23, no. 2, pp. 893-909, 2018.
- [13] Z. Whysall, M. Owtram, and S. J. J. o. M. D. Brittain, "The new talent management challenges of Industry 4.0," 2019.
- [14] H. Tabrizchi and M. K. Rafsanjani, "A survey on security challenges in cloud computing: issues, threats, and solutions," *The journal of supercomputing*, pp. 9493-9532, 2020.
- [15] S. Yi, L. Yuhe, and W. Yu, "Cloud computing architecture design of database resource pool based on cloud computing," *International Conference on Information Systems and Computer Aided Education*, pp. 180-183, 2018.
- [16] T. K. Damenu and C. Balakrishna, "Cloud security risk management: A critical review," *International Conference on Next Generation Mobile Applications, Services and Technologies*, pp. 370-375, 2015.
- [17] I. El Fray, "A comparative study of risk assessment methods, MEHARI & CRAMM with a new formal model of risk assessment (FoMRA) in information systems," in *IFIP International Conference on Computer Information Systems and Industrial Management*, 2012, pp. 428-442: Springer.
- [18] ISO/IEC-27005, *Information Technology. Security Techniques. Information Security Risk Management: ISO/IEC 27005: 2018*. International Organization for Standardization, 2018.
- [19] G. Wangen, C. Hallstensen, and E. Sneekenes, "A framework for estimating information security risk assessment method completeness," *Int. J. Inf. Secur.*, pp. 681–699, 2017.
- [20] *Guide for Conducting Risk Assessments* 2012.
- [21] L. Labuschagne, "A Framework for Comparing Different Information Security Risk Analysis Methodologies," *Proceedings of SAICSIT* 2005, pp. 95–103, 2005.
- [22] R. A. Caralli, J. F. Stevens, L. R. Young, and W. R. Wilson, "Introducing octave allegro: Improving the information security risk assessment process," *Carnegie-Mellon Univ Pittsburgh PA Software Engineering Inst2007*.
- [23] C. Fransson and L. Laukka, "Cloud risk analysis using OCTAVE Allegro: Identifying and analysing risks of a cloud service," *Linköping University*, pp. 1-42, 2021.
- [24] CRAMM. (2012). CRAMM Standard. Available: www.CRAMM.com
- [25] M. S. Lund, B. Solhaug, and K. Stølen, *Model-Driven Risk Analysis: The CORAS Approach*. Blindern: Springer, 2011.
- [26] J. Sheikh and BhupendraMalviya, "Managing Cyber Risk and Security In Cloud Computing," *International Journal of Advanced Computer Technology* pp. 122-126, 2020.
- [27] ISACA, *COBIT 5 for Risk Management*. 2013.
- [28] O. Akinrolaju, J. R. Nurse, A. Martin, S. J. C. New, and Security, "Cyber risk assessment in cloud provider environments: Current models and future needs," vol. 87, p. 101600, 2019.
- [29] S.FARIS, S. E. HASNAOUI, H.MEDROMI, H.IGUER, and A.SAYOUTI, "Toward an Effective Information Security Risk Management of Universities' Information Systems Using Multi Agent Systems, Itil, Iso 27002,Iso 27005," *International Journal of Advanced Computer Science and Applications*, pp. 114-118, 2014.
- [30] N. Mannane, Y. Bencharhi, B. Boulafour, and B. Regragui, "Survey: Risk assessment models for cloud computing: evaluation criteria," 3rd

- International Conference of Cloud Computing Technologies and Applications, pp. 1-5, 2017.
- [31] C. Lim and A. Suparman, "RISK ANALYSIS AND COMPARATIVE STUDY OF THE DIFFERENT CLOUD COMPUTING PROVIDERS IN INDONESIA," *New Perspectives in Information Systems and Technologies*, Volume, pp. 1-5, 2014.
- [32] S. K. Pandey and K. Mustafa, "A Comparative Study of Risk Assessment Methodologies for Information Systems," *Buletin Teknik Elektro dan Informatika*, pp. 111-122, 2012.
- [33] D. Gritzalis, G. Stergiopoulos, E. Vasilellis, and A. Anagnostopoulou, *Readiness Exercises: Are Risk Assessment Methodologies Ready for the Cloud?* Switzerland Springer, Cham, 2020.
- [34] S. Achara and R. Rathi, "Security Related Risks and their Monitoring in Cloud Computing," *International Journal of Computer Applications*, pp. 42-47, 2014.
- [35] E. Bailey and J. D. Becker, "A Comparison of IT Governance and Control Frameworks in Cloud Computing " 2014.